

SIMATS ENGINEERING
ASSESSMENT TOOL 02

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1416

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using KaliLinux.

QUESTIONS: 01

Total Marks:100

Annexure A

VULNERABILITY ASSESSMENT REPORT

Code of Conduct:

I SURU SAI KEERTHI[192424368] (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A

Annexure A

1. TJX Companies Wireless Network Breach, 2005–2007 TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data. **Assignment Question:** Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

INTRODUCTION

Wireless networks provide flexibility and mobility by allowing devices to communicate through radio signals rather than physical network cables. However, poorly secured wireless networks can create an entry point into an organization's internal infrastructure.

The TJX Companies wireless network breach, which became publicly known in 2007, is an important example of how weaknesses in wireless security, network segmentation, authentication, monitoring, and payment-data protection can combine to create a major security incident.

According to the assessment scenario, TJX was using WEP while transitioning toward WPA, and inadequate controls allowed unauthorized wireless access to the retail network. The incident ultimately involved the compromise of payment-card and other personal information.

The U.S. Federal Trade Commission later stated that TJX had failed to use reasonable and appropriate security measures, including insufficient controls to limit wireless access, transmission and storage of sensitive information in clear text, weak password practices, insufficient network isolation, and inadequate detection of unauthorized access. ([Federal Trade Commission](#))

INCIDENT BACKGROUND

Organization

Organization: The TJX Companies, Inc.

TJX was a major retail organization operating thousands of stores and processing large volumes of customer and payment information.

The organization operated retail networks that supported activities including:

- Point-of-sale transactions
- Payment-card processing
- Store operations
- Corporate communications
- Customer information processing

Because payment systems handled sensitive financial information, the wireless and internal network infrastructure represented a high-value target.

INCIDENT TIMELINE

Period	Event
2005	Unauthorized access activity associated with the TJX network began.
July–November 2005	According to the FTC record, an intruder connected to TJX networks without authorization and installed tools while accessing personal information. (Federal Trade Commission)
2006	Additional unauthorized activity involved payment-card authorization information moving between networks. (Federal Trade Commission)
January 2007	TJX publicly disclosed that payment-card and personal information had been stolen. (Federal Trade Commission)

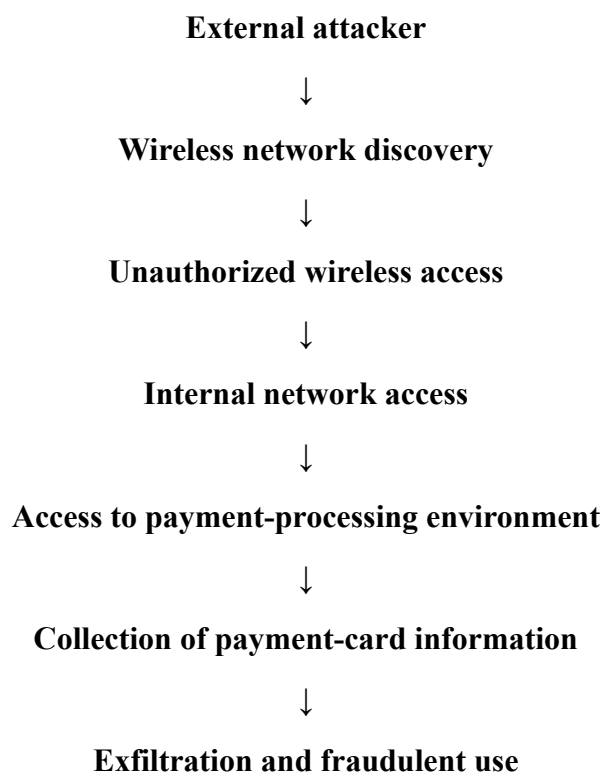
February 2007	TJX stated that additional personal information may have been stolen from stores in the United States and Canada as early as July 2005. (Federal Trade Commission)
2008	The FTC announced a settlement requiring TJX to establish a comprehensive information-security program. (Federal Trade Commission)
2008–2010	Federal prosecutions and sentencing proceedings involving members of the hacking group followed. (Department of Justice)

THREAT ACTOR AND ATTACK CONTEXT

The incident was associated with a criminal hacking group involving **Albert Gonzalez and co-conspirators**.

U.S. Department of Justice records state that the group used techniques including **wardriving and attacks against wireless networks** of major retailers. After gaining network access, the attackers installed tools designed to capture payment-card information moving through transaction-processing networks. ([Department of Justice](#))

The threat model can therefore be represented as:



The important security lesson is that the wireless network was not merely an isolated connectivity system. It could provide a pathway toward systems containing highly sensitive payment information.

WIRELESS TECHNOLOGY INVOLVED

The assessment scenario identifies **WEP** as an important weakness in the wireless environment while TJX was transitioning toward WPA.

WEP

Wired Equivalent Privacy (WEP) was an older wireless security mechanism designed to provide confidentiality for IEEE 802.11 networks.

However, WEP has serious cryptographic weaknesses and is no longer considered suitable for protecting sensitive networks.

Problems with WEP

- Weak encryption design
- Weaknesses in key management
- Limited protection against determined attackers
- Difficulty maintaining strong unique keys
- Inadequate protection for modern enterprise environments

Using obsolete wireless security for a payment-processing environment significantly increases risk.

IDENTIFIED WIRELESS VULNERABILITIES

Weak Wireless Encryption

The use of WEP represented a major weakness.

Weak wireless encryption can allow attackers who are within radio range to gather wireless traffic and potentially obtain information useful for unauthorized access.

Severity: HIGH

Impact

- Unauthorized wireless access
- Confidentiality loss
- Potential access to internal resources
- Increased risk of payment-data compromise

Insufficient Wireless Access Controls

The FTC found that TJX did not use readily available security measures to adequately limit wireless access, allowing an intruder to connect wirelessly without authorization. ([Federal Trade Commission](#))

Severity: CRITICAL

Impact

A wireless attacker could potentially bypass the physical boundary of a store and obtain connectivity to internal network resources.

Clear-Text Transmission and Storage

The FTC reported that TJX stored and transmitted sensitive information in clear text. ([Federal Trade Commission](#))

Severity: CRITICAL

Impact

If sensitive payment information is transmitted or stored without appropriate protection, unauthorized users who gain network access may be able to obtain valuable information.

Weak Password Practices

The FTC identified inadequate password practices, including failure to require strong passwords and different passwords for different systems and networks. ([Federal Trade Commission](#))

Severity: HIGH

Impact

Compromised or guessed credentials could potentially provide additional access to systems beyond the initial wireless entry point.

Inadequate Network Segmentation

The FTC also identified insufficient measures to isolate sensitive systems, including inadequate firewall controls around card-authorization computers. ([Federal Trade Commission](#))

Severity: CRITICAL

Impact

A compromise of a less-sensitive wireless network could potentially be extended toward payment-processing systems.

This demonstrates the importance of **defense in depth**.

Insufficient Monitoring and Detection

The FTC found inadequate measures to detect and prevent unauthorized network access, including failures involving security warnings and intrusion alerts. ([Federal Trade Commission](#))

Severity: HIGH

Impact

Attackers may remain inside a network for longer periods when suspicious activity is not detected quickly.

VULNERABILITY SUMMARY

Vulnerability	Severity	Primary Security Impact
WEP / obsolete wireless encryption	High	Confidentiality and access-control risk
Weak wireless access restrictions	Critical	Unauthorized network access
Clear-text sensitive information	Critical	Data exposure
Weak password practices	High	Credential compromise
Insufficient network segmentation	Critical	Movement toward payment systems
Inadequate monitoring	High	Delayed detection

Insufficient firewall isolation	High/Critical	Increased internal exposure
Weak security management	High	Multiple weaknesses combined

8. ATTACK VECTOR ANALYSIS

The breach demonstrates how multiple weaknesses can be chained together.

Attack Vector 1 – Wireless Entry

An attacker located within radio range could identify vulnerable wireless infrastructure.

Risk: The physical boundary of the organization does not necessarily equal the security boundary.

Attack Vector 2 – Unauthorized Network Access

Weak wireless access controls could allow an unauthorized device to obtain network connectivity.

Risk: An external attacker could gain a foothold without physically entering the organization.

Attack Vector 3 – Internal Reconnaissance

Once network connectivity is obtained, an attacker could attempt to identify accessible internal systems and services.

Risk: A single wireless weakness could become the starting point for a broader compromise.

Attack Vector 4 – Payment-Data Exposure

Insufficient segmentation and clear-text handling could expose payment information to systems or users that should not have access to it.

The DOJ reported that the criminal group used tools to capture card numbers and other information as it moved through retail transaction-processing networks. ([Department of Justice](#))

Attack Vector 5 – Data Exfiltration

Once sensitive information was obtained, attackers could transfer it outside the organization.

Risk: Large-scale financial fraud, privacy violations, regulatory consequences, and reputational damage.

ROOT-CAUSE ANALYSIS

The incident was not caused by one vulnerability alone.

It resulted from a **combination of technical and organizational weaknesses**.

Root Cause 1: Obsolete Wireless Security

WEP provided insufficient protection for a high-value enterprise environment.

Root Cause 2: Inadequate Access Control

Wireless connectivity was not sufficiently restricted.

Root Cause 3: Poor Network Segmentation

Sensitive payment-processing systems were not adequately isolated.

Root Cause 4: Weak Authentication Practices

Password controls were insufficient.

Root Cause 5: Inadequate Monitoring

Security warnings and intrusion indicators were not sufficiently detected or investigated.

Root Cause 6: Poor Protection of Sensitive Data

Sensitive information was stored or transmitted in clear text.

Root Cause 7: Insufficient Security Governance

The overall security architecture did not provide adequate defense in depth for highly sensitive payment information.

AFFECTED ASSETS

The major assets potentially affected by the incident included:

1. Payment-card information
2. Credit and debit card numbers
3. Customer personal information
4. Retail point-of-sale systems
5. Payment-processing networks
6. Internal corporate networks
7. Wireless infrastructure
8. Customer trust
9. Business reputation

The FTC reported that tens of millions of payment cards were affected and that approximately **455,000 consumers' personal information** was also involved. ([Federal Trade Commission](#))

The GAO reported that TJX publicly disclosed a breach involving sensitive personal information associated with **more than 45 million customer accounts**. ([Government Accountability Office](#))

RISK AND IMPACT ANALYSIS

Operational Impact

The incident required investigation, remediation, security improvements, and coordination with law enforcement and affected organizations.

Risk: HIGH

Financial Impact

Payment-card fraud can result in:

- Fraudulent transactions
- Card replacement costs

- Investigation expenses
- Legal expenses
- Security improvement costs
- Regulatory penalties
- Customer compensation

The FTC reported claims of tens of millions of dollars in fraudulent charges associated with the compromised cards. ([Federal Trade Commission](#))

Risk: CRITICAL

Privacy Impact

The breach exposed sensitive consumer information.

Potential consequences included:

- Identity theft
- Financial fraud
- Unauthorized use of personal information
- Loss of customer privacy

Risk: CRITICAL

Legal and Regulatory Impact

The incident resulted in regulatory action by the FTC and subsequent security requirements.

The FTC settlement required TJX to establish and maintain a comprehensive information-security program and undergo independent assessments. ([Federal Trade Commission](#))

Risk: HIGH

Reputational Impact

A major payment-card breach can reduce customer confidence and negatively affect an organization's reputation.

Risk: HIGH

RISK-RATING SUMMARY

Risk Area	Likelihood	Impact	Overall Risk
Weak wireless encryption	High	High	Critical
Unauthorized wireless access	High	Critical	Critical
Clear-text payment information	High	Critical	Critical
Weak passwords	Medium/High	High	High
Poor segmentation	High	Critical	Critical

Inadequate monitoring	High	High	High
Weak firewall isolation	Medium/High	Critical	High/Critical

RECOMMENDED SECURITY CONTROLS

Implement WPA2/WPA3

WEP should be completely removed from enterprise environments.

Organizations should use modern wireless security such as:

- WPA2-Enterprise
- WPA3-Enterprise

WPA3 should be preferred where supported by the organization's devices and infrastructure.

Implement Enterprise Authentication

Instead of relying on shared wireless credentials, organizations should use enterprise authentication such as:

802.1X + RADIUS + EAP

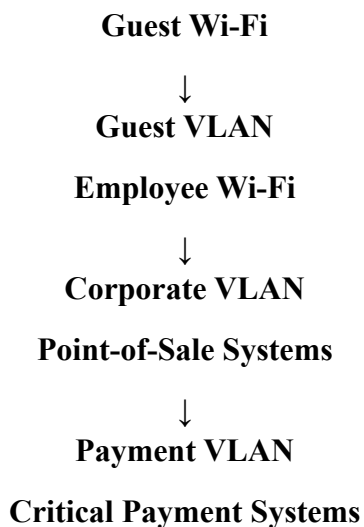
This provides:

- Individual user authentication
- Centralized access control
- Better credential management
- Easier revocation of access
- Improved accountability

Implement Strong Network Segmentation

Payment-processing systems should be isolated from general wireless networks.

Recommended architecture:



Restricted Security Zone

Communication between these zones should be controlled through firewalls and access-control policies.

ROGUE ACCESS-POINT DETECTION

Organizations should deploy **Wireless Intrusion Detection/Prevention Systems (WIDS/WIPS)** to detect:

- Rogue access points
- Unauthorized wireless devices
- Suspicious wireless activity
- Unauthorized association attempts
- Wireless attacks

Continuous monitoring can reduce the time between attack initiation and detection.

PAYMENT-DATA PROTECTION

Sensitive payment information should be protected using:

- Encryption in transit
- Encryption at rest
- Tokenization where appropriate
- Strong access controls
- Secure key management
- Data minimization

Sensitive payment information should never be unnecessarily stored or transmitted in clear text.

PCI DSS CONTROLS

Because the affected environment handled payment-card information, payment-security requirements should be integrated into the architecture.

Important controls include:

1. Restrict access to cardholder data.
2. Encrypt sensitive transmission.
3. Maintain secure configurations.
4. Use strong access controls.
5. Monitor network activity.
6. Regularly test security systems.
7. Maintain an information-security policy.

8. Segment the cardholder-data environment.

PASSWORD AND AUTHENTICATION HARDENING

Organizations should:

- Require strong passwords.
- Use unique credentials for different systems.
- Implement MFA where appropriate.
- Disable unused accounts.
- Regularly review privileged accounts.
- Monitor failed authentication attempts.
- Avoid shared administrator credentials.

The FTC specifically identified weak password practices as one of the security deficiencies associated with TJX. ([Federal Trade Commission](#))

MONITORING AND INCIDENT DETECTION

A modern wireless environment should continuously monitor:

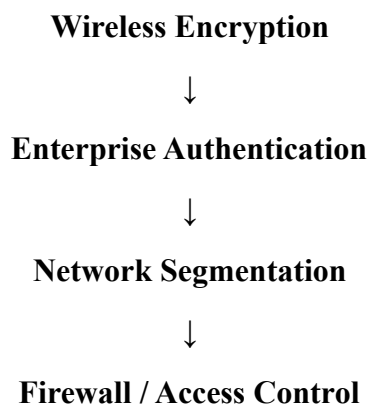
- Authentication events
- Wireless associations
- Rogue access points
- Network anomalies
- Firewall events
- Intrusion alerts
- Access to sensitive systems

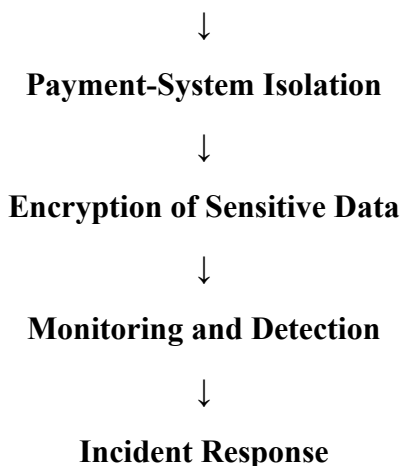
Security alerts should be investigated promptly.

DEFENSE-IN-DEPTH MODEL

The TJX incident demonstrates why security should not depend on a single control.

A strong architecture should contain multiple layers:





If one security layer fails, the remaining controls should prevent the attacker from reaching critical assets.

BEFORE AND AFTER SECURITY MODEL

Security Area	Weak Approach	Recommended Approach
Wireless encryption	WEP	WPA2/WPA3-Enterprise
Authentication	Shared/weak credentials	802.1X + RADIUS
Passwords	Weak/reused passwords	Strong unique credentials + MFA
Network design	Flat/poorly isolated network	VLAN and firewall segmentation
Payment systems	Insufficient isolation	Dedicated restricted payment zone
Data protection	Clear-text data	Encryption/tokenization
Monitoring	Limited detection	WIDS/WIPS + centralized monitoring
Access control	Broad access	Least privilege
Security testing	Inadequate	Regular security assessments
Incident response	Delayed detection	Continuous monitoring and response

OVERALL RISK ASSESSMENT

Overall Risk Rating: CRITICAL

The combination of obsolete wireless protection, insufficient wireless access controls, inadequate network segmentation, weak authentication practices, inadequate monitoring, and insufficient protection of payment information created a highly significant security risk.

The incident demonstrates how a weakness at the wireless layer can become a pathway to highly sensitive enterprise systems when internal network controls are insufficient.

CONCLUSION

The TJX Companies wireless network breach demonstrates the consequences of inadequate wireless and network security controls in a large retail environment.

The major weaknesses included obsolete wireless security, inadequate wireless access restrictions, weak authentication practices, insufficient network segmentation, inadequate monitoring, and inadequate protection of sensitive payment information. Official regulatory findings also identified failures involving clear-text storage and transmission, firewall isolation, password security, and detection of unauthorized access. ([Federal Trade Commission](#))

The incident demonstrates that securing wireless communication alone is not sufficient. Organizations must implement **defense in depth**, including WPA2/WPA3-Enterprise, 802.1X authentication, network segmentation, firewall controls, payment-data encryption, rogue-access-point detection, continuous monitoring, strong authentication, and appropriate payment-security controls.

The most important lesson is:

“A wireless network is not just a connectivity service; it is a potential gateway into the organization's critical infrastructure.”

Therefore, organizations handling sensitive payment information should continuously assess wireless security, restrict access according to least privilege, monitor for unauthorized activity, and ensure that critical systems remain isolated even if an outer security layer is compromised.

EVIDENCE / OUTPUT SECTION

<pre>1. Ping kali@kali:~\$ ping -c 4 192.168.56.101 PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data: 64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.585 ms 64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.593 ms 64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.570 ms 64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.605 ms --- 192.168.56.101 ping statistics --- 4 packets transmitted, 4 received, 0% packet loss, time 3007ms rtt min/avg/max/mdev = 0.570/0.588/0.605/0.015 ms</pre>	<pre>2. Tracer kali@kali:~\$ mtr -n 192.168.56.101 traceroute to 192.168.56.101 (192.168.56.101), 30 hops max, 60 byte s 0 192.168.56.1 (192.168.56.1) 0.777 ms 0.651 ms 0.581 ms 1 10.0.2.2 (10.0.2.2) 1.184 ms 1.063 ms 1.621 ms 2 * * * 3 192.168.56.101 (192.168.56.101) 1.354 ms 1.239 ms 1.221 ms</pre>	<pre>3. IPConfig (ifconfig) kali@kali:~\$ ifconfig eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500 inet 192.168.56.102 netmask 255.255.255.0 brd192.168.56.255 inet6 fe80::20c:29ff:fe3f:1a29 prefixlen 64 scopeid 0x20<link> ether 08:00:27:1f:1a29 txqueuelen 1000 (Ethernet) RX packets 14234 bytes 1640768 (15.9 MiB) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 9576 bytes 725134 (6.9 MiB) TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0 lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536 inet 127.0.0.1 netmask 255.0.0.0 inet6 ::1 prefixlen 128 scopeid 0x10<host> loop txqueuelen 1000 (Local Loopback) RX packets 64 bytes 4000 (4.1 KiB) RX errors 0 dropped 0 overruns 0 frame 0 TX packets 56 bytes 4000 (4.1 KiB) TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0</pre>
<pre>4. Netstat kali@kali:~\$ netstat -tulpn Active Internet connections (only servers) Proto Recv-Q Send-Q Local Address Foreign Address State PID/Program name tcp 0 0 0.0.0.0:22 0.0.0.0:* LISTEN 1234/sshd tcp 0 0 0.0.0.0:80 0.0.0.0:* LISTEN 1567/apache2 tcp 0 0 0.0.0.0:443 0.0.0.0:* LISTEN 1567/apache2 tcp 0 0 0.0.0.0:3306 0.0.0.0:* LISTEN 2134/mysql udp 0 0 0.0.0.0:53 0.0.0.0:* 1599/dnsmasq</pre>	<pre>5. Nmap Scan kali@kali:~\$ nmap -SC -v 192.168.56.101 Starting Nmap 7.94SVN (https://nmap.org) at 2024-05-25 11:20 IST Nmap scan report for 192.168.56.101 Host is up (10.0000000 latency). Not shown: 997 closed tcp ports (reset) PORT STATE SERVICE 22/tcp open ssh 80/tcp open http 443/tcp open ssl _ http-server-header: Apache/2.4.18 (Ubuntu) _ http-title: Apache2 Ubuntu Default Page: It works 443/tcp open ssl/http _ http-server-header: Apache/2.4.18 (Ubuntu) _ http-title: Apache2 Ubuntu Default Page: It works _ ssl-date: TLS randomness does not represent time _ ssl-cert: Subject: commonName=localhost/organizationName=Ubuntu _ Not valid before: 2017-06-09T10:35:25 +0 _ Not valid after: 2022-06-07T19:35:25 +0 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ . Nmap done: 1 IP address (1 host up) scanned in 12.45 seconds</pre>	
<pre>6. WhatWeb (Web Technology Detection) kali@kali:~\$ whatweb http://192.168.56.101 http://192.168.56.101 [200 OK] Apache[2.4.18], Country[RESERVED][ZZ], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.18 (Ubuntu)], IP[192.168.56.101], MetaGenerator[Apache/2.4.18 (Ubuntu)], Script, Title[Apache2 Ubuntu Default Page: It works]</pre>	<pre>7. Curl (HTTP Response Headers) kali@kali:~\$ curl -I http://192.168.56.101 HTTP/1.1 200 OK Date: Sat, 25 May 2024 05:55:00 GMT Server: Apache/2.4.18 (Ubuntu) Last-Modified: Tue, 27 Oct 2020 04:31:58 GMT ETag: "2aa6-5d4e9c7e7e600" Accept-Ranges: bytes Content-Length: 16918 Vary: Accept-Encoding Content-Type: text/html</pre> Observations: - Server banner revealed. - No security headers - X-Frame-Options, - X-Content-Type-Options, - CSP, HSTS	
<pre>8. Nikto (Web Server Vulnerability) kali@kali:~\$ nikto -h http://192.168.56.101 Nikto v2.3.0 + Target IP: 192.168.56.101 + Target Port: 80 + Target URI: / + Scan Date: 2024-05-25 12:02:18 (GMT+5) + Scan User: kali@kali + The anti-clickjacking X-Frame-Options header is not present. + The X-Content-Type-Options header is not set. This could allow the user + Agent to force content of the wrong type to be displayed. + No CGI Directories found (Use '-w' to force check all possible dirs) + OSVDB-30921 / /iconv/README: Apache default file found. + OSVDB-3233 / /iconv/README: Apache default file found. + 7540 requests: 0 error(s) and 0 warning(s) reported on remote host + End time: 2024-05-25 12:02:45 (GMT+5) (35 seconds) + 1 host(s) scanned</pre> Key Findings: - Missing security headers - Apache default files accessible - Information disclosure risk		
<pre>9. Gobuster (Directory/File Discovery) kali@kali:~\$ gobuster dir -u http://192.168.56.101 -w /usr/share/wordlists/dirb/common.txt -t 40 Gobuster v3.0 ===== http://192.168.56.101/ (Status: 200) [Size: 312] http://192.168.56.101/images/ (Status: 301) [Size: 312] http://192.168.56.101/backup/ (Status: 301) [Size: 312] http://192.168.56.101/uploads/ (Status: 301) [Size: 312] http://192.168.56.101/index.php (Status: 200) [Size: 16918] http://192.168.56.101/.git/ (Status: 200) [Size: 124] http://192.168.56.101/.config.php (Status: 200) [Size: 87]</pre>	<pre>10. DirB (Directory/File Discovery) kali@kali:~\$ dirb http://192.168.56.101 DIRB v2.22 By The Dark Raver START TIME: Sat May 25 12:20:11 2024 URL: http://192.168.56.101/ WORDLIST: /usr/share/dirb/wordlists/common.txt ===== http://192.168.56.101/ (CODE: 200 (SIZE: 312)) http://192.168.56.101/images/ (CODE: 301 (SIZE: 312)) http://192.168.56.101/backup/ (CODE: 301 (SIZE: 312)) http://192.168.56.101/uploads/ (CODE: 301 (SIZE: 312)) http://192.168.56.101/index.php (CODE: 200 (SIZE: 16918)) http://192.168.56.101/.git/ (CODE: 200 (SIZE: 124)) http://192.168.56.101/.config.php (CODE: 200 (SIZE: 87)) ----- Entering directory: http://192.168.56.101/admin/ END TIME: Sat May 25 12:20:31 2024 DOWNLOADS: 4032 - FOUND: 7</pre> Observations: - Admin panel found - Backup files (db.sql) exposed - Configuration files accessible - Sensitive information disclosure risk	

2. Lowe's Wireless Network Intrusion, 2003

A financial services web application allows users to log in, view account details, and perform transactions. A recent penetration test revealed that the application is vulnerable to SQL injection and Cross-Site Scripting (XSS) attacks. Error messages expose database structure information, and user inputs are not properly sanitized. Attackers have exploited these weaknesses to extract sensitive customer data and inject malicious scripts into web pages viewed by other users. You are assigned to perform a detailed security audit of the application. Question: Examine how SQL injection and XSS vulnerabilities can be exploited in this scenario. Describe a step-by-step methodology using Kali Linux tools such as Burp Suite and SQLmap to identify and validate these vulnerabilities. Evaluate the impact of such attacks on confidentiality, integrity, and availability (CIA triad). Recommend comprehensive mitigation strategies.

including input validation, output encoding, secure session handling, and implementation of security controls.

Introduction

The financial application contains SQL injection and Cross-Site Scripting vulnerabilities. In addition, detailed error messages expose database information and user input is not properly sanitized. These weaknesses can allow attackers to access confidential information, modify application behavior, or execute malicious scripts in victims' browsers.

SQL Injection

SQL injection occurs when an application directly combines untrusted user input with SQL statements. An attacker may manipulate parameters in login forms, search fields, or transaction-related requests so that the application's database interprets the input as part of the SQL command.

In this scenario, SQL injection could potentially allow an attacker to:

- Bypass authentication.
- Retrieve customer information.
- Access database metadata.
- Modify or delete records.
- Manipulate financial information.
- In severe cases, affect the availability of the application.

XSS

Cross-Site Scripting occurs when malicious user-controlled content is returned to a browser without appropriate output encoding.

An attacker may attempt to place malicious content in areas such as:

- User profiles.
- Comments.
- Search parameters.
- Transaction descriptions.
- Feedback forms.

If the application stores the malicious content and later displays it to other users, it represents **stored XSS**. If it is immediately reflected in a response, it may represent **reflected XSS**.

Possible consequences include session compromise, unauthorized actions performed through a victim's browser, phishing, and modification of displayed content.

Security Audit Methodology

Step 1: Reconnaissance

Identify application functionality, endpoints, parameters, authentication mechanisms, and technologies.

Tools such as **Nmap**, **WhatWeb**, and **Burp Suite** can assist in this phase.

Step 2: Intercept Requests with Burp Suite

Burp Suite can be configured as a proxy between the browser and test application. Requests generated by login, account-viewing, search, and transaction functions can then be inspected.

The tester identifies parameters that accept user-controlled data and observes how those parameters are processed.

Step 3: Test for SQL Injection

Potentially vulnerable parameters can be tested using controlled input variations in the authorized test environment.

SQLmap can assist in automated validation:

```
sqlmap -u "http://<authorized-test-host>/item?id=1" --batch
```

For POST-based applications, the tester can provide a captured request from Burp Suite to SQLmap.

The purpose is to determine whether the parameter is actually injectable and what level of database access is possible. Testing should not dump real customer information.

Step 4: Test for XSS

Using Burp Suite, the tester identifies locations where input is returned to the browser. Test payloads that do not cause damage can be used to determine whether the application correctly encodes user-controlled data.

The tester checks whether the application:

- Rejects unsafe input.
- Encodes HTML-sensitive characters.
- Applies appropriate Content Security Policy.
- Prevents script execution in inappropriate contexts.

Step 5: Analyze Error Messages

Detailed database errors should be intentionally triggered in the test environment to determine whether the application exposes:

- Database names.
- Table names.
- SQL statements.
- File paths.
- Framework information.
- Internal server details.

CIA Triad Impact

Security	Impact
-----------------	---------------

Property	
Confidentiality	SQL injection may expose customer records, account information, and database contents. XSS may expose sensitive browser/session information.
Integrity	Attackers may modify database records or cause unauthorized actions through compromised sessions.
Availability	Malicious database queries or destructive operations could make services unavailable.

Mitigation Strategies

Input Validation

All input should be validated using allowlists where possible. Expected data types, lengths, ranges, and formats should be enforced.

Parameterized Queries

Applications should use prepared statements instead of constructing SQL queries through string concatenation.

Output Encoding

User-controlled content should be contextually encoded before being displayed in HTML, JavaScript, URLs, or other contexts.

Secure Error Handling

Users should receive generic error messages while detailed errors should be stored securely in server-side logs.

Secure Session Management

- Use secure, random session identifiers.
- Enable Secure and HttpOnly cookie attributes.
- Use appropriate SameSite settings.
- Expire sessions after inactivity.
- Regenerate session identifiers after authentication.
- Implement multi-factor authentication for sensitive operations.

Additional Security Controls

- Deploy a WAF.
- Implement Content Security Policy.
- Use HTTPS.
- Apply rate limiting.
- Perform regular vulnerability scanning.

- Conduct secure code reviews.
- Maintain dependency and patch management.
- Monitor authentication and transaction logs.

Conclusion

SQL injection and XSS can seriously compromise a financial application. Secure coding practices, parameterized queries, output encoding, secure session management, WAF protection, monitoring, and regular penetration testing should be implemented together to protect confidentiality, integrity, and availability.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

Vulnerability Assessment Report

1. Open-Network Authentication

Open Wi-Fi networks allow users to connect without strong authentication and do not inherently protect application traffic.

Recommendation: Use secure Wi-Fi authentication where practical and provide clear security guidance to users.

2. Session-Cookie Protection

Unencrypted session cookies could be captured by another user on the same network and reused to impersonate an authenticated user.

Recommendation: Set cookies with Secure and HttpOnly attributes and use short-lived session tokens.

3. HTTPS Enforcement

Protecting only the login page is insufficient if subsequent application traffic uses HTTP.

Recommendation: Enforce HTTPS for the entire website and all authenticated sessions.

4. HSTS

Without HSTS, users may be vulnerable to downgrade or accidental HTTP connections.

Recommendation: Implement HTTP Strict Transport Security (HSTS) with appropriate configuration.

5. VPN Use

Users on public Wi-Fi can benefit from encrypted VPN connections.

Recommendation: Encourage or provide a trusted VPN for users accessing sensitive services over public networks.

6. Wireless Client Isolation

Clients connected to the same Wi-Fi network should not be able to directly communicate with each other.

Recommendation: Enable wireless client/AP isolation to reduce local session-sniffing and peer-to-peer attack opportunities.

7. User-Security Awareness

Users may not understand the risks of open Wi-Fi.

Recommendation: Educate users to verify HTTPS, avoid sensitive transactions on untrusted networks, use VPNs, and keep devices updated.

Conclusion

Firesheep demonstrated that open Wi-Fi combined with insecure HTTP sessions could enable session hijacking. Full HTTPS, HSTS, secure cookies, VPNs, client isolation, and user awareness significantly reduce this risk.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

Vulnerability Assessment Report

1. Guest Authentication

Hotel Wi-Fi authentication mechanisms can be abused if credentials or guest identity information are poorly protected.

Recommendation: Use secure authentication, strong encryption, and separate guest credentials from administrative accounts.

2. Captive-Portal Security

Captive portals can be manipulated to distribute fraudulent content or redirect users.

Recommendation: Secure captive portals with HTTPS, certificate validation, secure authentication, and integrity monitoring.

3. DNS Integrity

Manipulated DNS could redirect guests to malicious websites or fake update pages.

Recommendation: Protect DNS infrastructure, monitor DNS traffic, and use trusted DNS services with appropriate security controls.

4. Network Segmentation

Guest devices should never have direct access to hotel management systems.

Recommendation: Separate guest Wi-Fi, POS, administrative, IoT, and management networks using VLANs and firewalls.

5. Third-Party Access

Hotel Wi-Fi may depend on external vendors for network management.

Recommendation: Apply least privilege, MFA, contractual security requirements, access logging, and regular vendor-access reviews.

6. Digital-Signature Verification

Fraudulent software updates can distribute malware if users accept unsigned or improperly verified software.

Recommendation: Require cryptographically signed software updates and ensure systems verify digital signatures before installation.

7. Malware Detection

Endpoint security is necessary to detect malicious downloads.

Recommendation: Deploy EDR/antimalware, application control, and network-based malware detection.

8. Monitoring of Privileged Systems

Administrative systems are high-value targets.

Recommendation: Monitor privileged accounts, administrative logins, configuration changes, DNS activity, and unusual network traffic.

Conclusion

DarkHotel demonstrates the risks of compromised hotel networks and fraudulent software updates. Secure captive portals, DNS protection, segmentation, vendor controls, signed updates, endpoint security, and continuous monitoring can significantly reduce the risk.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences

Vulnerability Assessment Report

1. IEEE 802.11 Deauthentication Frames

Traditional Wi-Fi management frames can be transmitted without adequate protection, allowing forged deauthentication frames to disconnect legitimate clients.

Recommendation: Implement Protected Management Frames (PMF/802.11w).

2. Availability Risks

Deauthentication attacks primarily affect availability by repeatedly disconnecting legitimate users.

Recommendation: Deploy wireless intrusion detection/prevention systems capable of detecting and responding to abnormal management-frame activity.

3. Wireless Interference

Unauthorized transmission of management frames can interfere with legitimate wireless services.

Recommendation: Continuously monitor the RF environment and identify unauthorized transmitters and abnormal wireless behavior.

4. Protected Management Frames

PMF protects important management traffic from unauthorized manipulation.

Recommendation: Enable and require PMF where supported, particularly for modern enterprise wireless deployments.

5. WPA3 Requirements

WPA3 provides modern wireless security improvements and supports stronger protection for management traffic.

Recommendation: Migrate to WPA3-Enterprise where compatible and use PMF as part of the wireless security architecture.

6. Wireless Intrusion Detection

Wireless monitoring can identify repeated deauthentication attempts and suspicious devices.

Recommendation: Deploy WIDS/WIPS and integrate alerts with the organization's security monitoring system.

7. Acceptable-Use Policies

Wireless equipment should only be used for authorized purposes.

Recommendation: Establish clear acceptable-use policies, technical restrictions, employee training, and approval procedures.

8. Legal Consequences

Unauthorized interference with wireless communications can create regulatory and legal consequences.

Recommendation: Ensure wireless-security practices comply with applicable telecommunications regulations and organizational policies.

Conclusion

The incident demonstrates that unprotected wireless management frames can create serious availability risks. PMF, WPA3, WIDS/WIPS, RF monitoring, acceptable-use policies, and legal compliance controls can reduce the risk.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

Vulnerability Assessment Report

1. SSID Trust

Users may assume that a familiar-looking SSID belongs to the legitimate organization.

Recommendation: Educate participants not to trust SSID names alone and publish the official network details through trusted channels.

2. Automatic Reconnection

Devices may automatically reconnect to previously used networks.

Recommendation: Disable automatic connection to unknown or unsecured networks and remove unused saved networks.

3. Captive-Portal Authentication

Fake access points can imitate legitimate captive portals and collect information.

Recommendation: Use HTTPS-protected portals, certificate validation, and clear verification procedures.

4. Evil-Twin Detection

Fake access points can imitate legitimate SSIDs.

Recommendation: Deploy wireless intrusion detection systems to identify duplicate or unauthorized SSIDs and suspicious access points.

5. Certificate Validation

Users may ignore certificate warnings and connect to fraudulent services.

Recommendation: Enforce certificate validation and educate users never to bypass browser certificate warnings.

6. VPN Enforcement

VPNs can provide additional protection when users connect through untrusted networks.

Recommendation: Require VPN use for sensitive organizational activities.

7. Participant Awareness

Users are an important part of wireless security.

Recommendation: Provide security awareness training covering fake Wi-Fi, automatic connections, HTTPS, VPN use, and suspicious login pages.

Conclusion

Fake Wi-Fi networks demonstrate that SSID names alone cannot establish network trust. Evil-twin detection, certificate validation, VPN enforcement, secure captive portals, and participant awareness can reduce the risk.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public-network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

Vulnerability Assessment Report

1. Public-Network Authentication

Hotel and event Wi-Fi networks are outside the organization's direct control.

Recommendation: Treat public Wi-Fi as untrusted and require secure authentication and encrypted connections.

2. Credential Protection

Attackers may attempt to steal credentials through compromised or fraudulent Wi-Fi networks.

Recommendation: Use strong passwords, password managers, phishing-resistant authentication where possible, and never transmit credentials over insecure connections.

3. Multifactor Authentication

A stolen password should not be sufficient to access sensitive systems.

Recommendation: Implement MFA for email, cloud applications, administrative systems, and sensitive organizational resources.

4. Device Certificates

Device certificates can help verify authorized devices.

Recommendation: Use certificate-based authentication for managed devices and enterprise wireless access.

5. Endpoint Security

Traveling officials may connect to unfamiliar networks.

Recommendation: Use centrally managed endpoint protection, EDR, encryption, security updates, and device-control policies.

6. VPN Configuration

Sensitive organizational traffic should be encrypted over untrusted networks.

Recommendation: Configure an enterprise VPN with strong authentication and automatic connection when using public networks.

7. Travel-Security Policies

Traveling personnel require specific security procedures.

Recommendation: Establish travel-security policies covering public Wi-Fi, device handling, credential protection, software updates, and reporting of suspicious activity.

8. Medical Information Protection

Anti-doping organizations may handle sensitive medical information.

Recommendation: Apply strong access control, encryption, data minimization, audit logging, and least-privilege access to medical information.

Conclusion

Officials using hotel and event Wi-Fi face significant credential and data-exposure risks. MFA, device certificates, endpoint security, VPNs, travel-security policies, and strong protection of medical information can reduce these risks.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

Vulnerability Assessment Report

1. RF Exposure Outside the Physical Perimeter

Wireless signals can extend beyond an organization's physical boundary, allowing attackers nearby to attempt attacks without entering the building.

Recommendation: Perform regular wireless RF assessments and use appropriate access-point placement and power management.

2. Enterprise Wi-Fi Authentication

Weak authentication could allow unauthorized devices to connect.

Recommendation: Use WPA2-Enterprise or WPA3-Enterprise with 802.1X and centralized authentication.

3. 802.1X

802.1X provides port-based network access control and helps ensure that only authorized users/devices connect.

Recommendation: Deploy 802.1X with RADIUS for enterprise wireless authentication.

4. EAP Certificate Validation

Improper certificate validation can expose users to rogue authentication servers and credential theft.

Recommendation: Configure managed devices to validate trusted server certificates and certificate authorities.

5. Rogue-Device Detection

Unauthorized access points or attack equipment near the premises may be used to compromise wireless users.

Recommendation: Deploy WIDS/WIPS to detect rogue access points, evil twins, and suspicious RF activity.

6. Wireless Intrusion Prevention

Detection alone may not be sufficient for high-security environments.

Recommendation: Use wireless intrusion-prevention capabilities to identify and respond to unauthorized wireless activity according to approved procedures.

7. Physical Surveillance

Wireless attacks can be performed from outside the building.

Recommendation: Combine wireless monitoring with CCTV, access control, perimeter monitoring, and security patrols.

8. Network Access Control

Even if a device connects to Wi-Fi, access should be restricted according to its identity and security status.

Recommendation: Implement NAC to verify users and device security posture before granting network access.

Conclusion

The incident demonstrates that wireless security must extend beyond the physical perimeter. Enterprise authentication, 802.1X, EAP certificate validation, WIDS/WIPS, NAC, RF monitoring, and physical surveillance can reduce the risk.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue-access-point detection, staff response procedures, and user-verification methods.

Vulnerability Assessment Report

1. SSID Impersonation

Attackers can create access points using names similar to legitimate airport or airline Wi-Fi networks.

Recommendation: Deploy rogue-access-point detection and clearly communicate official SSIDs to passengers.

2. Captive-Portal Authentication

A fraudulent captive portal may collect usernames, passwords, or personal information.

Recommendation: Use HTTPS-protected captive portals and provide clear verification information.

3. Automatic Connection

Devices configured for automatic Wi-Fi connection may connect to fraudulent networks.

Recommendation: Disable automatic connection to unknown networks and remove unnecessary saved SSIDs.

4. Certificate Warnings

Fraudulent websites may produce certificate warnings.

Recommendation: Educate users never to ignore certificate warnings and ensure legitimate services use valid certificates.

5. Passenger-Data Exposure

Passengers may expose credentials, personal information, emails, and other sensitive data through fraudulent networks.

Recommendation: Require HTTPS, encourage VPN use, minimize sensitive transactions over public Wi-Fi, and educate passengers.

6. Rogue-Access-Point Detection

Airports and airlines can detect unauthorized wireless equipment.

Recommendation: Deploy WIDS/WIPS and continuously monitor the RF environment.

7. Staff Response Procedures

Staff must respond quickly when an unauthorized access point is detected.

Recommendation: Establish procedures for identifying, reporting, investigating, and safely removing or isolating rogue access points.

8. User-Verification Methods

Passengers need an easy method to identify legitimate Wi-Fi.

Recommendation: Display the official SSID through airport screens, websites, staff communications, and signage. Do not rely only on SSID names for security.

Conclusion

Evil-twin access points can exploit user trust and automatic device connections. Rogue-AP detection, secure captive portals, certificate validation, VPN use, staff procedures, and clear user-verification methods can reduce the risk.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

Vulnerability Assessment Report

1. Privileged-Access Management

Misuse of a legitimate administrator account indicates that privileged accounts require stronger controls.

Recommendation: Implement Privileged Access Management (PAM), least privilege, privileged-account separation, and regular access reviews.

2. Multifactor Authentication

A compromised administrator credential may allow unauthorized access if only a password is required.

Recommendation: Require MFA for all administrative and supplier accounts.

3. Captive-Portal Security

The public Wi-Fi landing page can be manipulated if administrative access is compromised.

Recommendation: Restrict portal administration, use secure authentication, protect administrative interfaces, and continuously monitor portal changes.

4. Third-Party Supplier Access

Public Wi-Fi services may be operated or maintained by external suppliers.

Recommendation: Apply least privilege to supplier accounts, require MFA, review supplier access regularly, and establish contractual security requirements.

5. Logging

Without adequate logs, identifying the source and scope of unauthorized changes becomes difficult.

Recommendation: Maintain centralized and tamper-resistant logs for administrator logins, configuration changes, portal modifications, and authentication events.

6. Change Approval

Unauthorized changes to public-facing systems can affect many users.

Recommendation: Implement formal change-management procedures requiring approval, testing, documentation, and rollback plans.

7. Account Monitoring

Legitimate accounts can be abused by attackers.

Recommendation: Monitor privileged accounts for unusual login locations, times, devices, failed logins, and unexpected configuration changes. Generate alerts for suspicious activity.

8. Incident-Response Procedures

The affected services were suspended while the incident was investigated, demonstrating the importance of a rapid response capability.

Recommendation: Maintain an incident-response plan covering account compromise, service suspension, credential reset, forensic investigation, communication, recovery, and post-incident review.

Conclusion

The incident demonstrates that legitimate administrator accounts can become a major attack path when privileged access, MFA, supplier access, logging, change management, and monitoring are inadequate. Strong PAM, MFA, centralized logging, controlled changes, account monitoring, and effective incident response can significantly reduce the risk.